

Incident Response Playbook

Phishing · Ransomware · Insider Threat

Authored by: Nivedhitha K.S. (Crystal)
TCS Enterprise IT · 3.7 years SOC operations experience
github.com/NivedhithaKS-SEC · Bugcrowd: NivedhithaKS
Version 1.0 · May 2026

Table of Contents

1.	Playbook Overview & Scope	3
2.	IOC Extraction Reference	3
3.	Scenario 1 — Phishing Attack	4
4.	Scenario 2 — Ransomware Outbreak	5
5.	Scenario 3 — Insider Threat	6
6.	MITRE ATT&CK; Quick Reference	7
7.	Escalation Matrix & Communication	7

1. Playbook Overview & Scope

This playbook defines the end-to-end incident response lifecycle for three high-priority threat scenarios faced in enterprise environments. It is based on the NIST SP 800-61 Rev 2 framework and aligned with MITRE ATT&CK TTPs. All scenarios follow the same six-phase structure.

1 • Preparation	SIEM rules, playbook maintenance, contact lists, asset inventory current
2 • Detection	SIEM alert fires → analyst receives ticket → severity triage begins
3 • Containment	Isolate affected systems, block indicators, prevent lateral spread
4 • Eradication	Remove malware/persistence, patch vulnerability, reset credentials
5 • Recovery	Restore from clean backup, validate integrity, monitor closely for 72 hrs
6 • Lessons Learned	Post-incident report within 5 business days, update detection rules

2. IOC Extraction Reference

Before triaging any alert, extract and document all Indicators of Compromise. Log every IOC in the ticketing system immediately — do not wait for containment. Cross-reference against threat intel feeds (VirusTotal, AbuseIPDB, Shodan).

IOC Type	Example / Format	Extraction Tool
Sender email address	ceo.impersonation@g00gle.com	Email header analysis, MX Toolbox
Source IP address	185.234.219.47	Wireshark, SIEM log pivot
Malicious domain	update-security-patch[.]com	Passive DNS, VirusTotal, urlscan.io
File hash (SHA-256)	3a5f6b...c29d (64 chars)	PowerShell Get-FileHash, CrowdStrike

C2 beacon URL	http://185.x.x.x/c2/check-in	Wireshark HTTP stream, Zeek logs
Registry persistence	HKCU\Software\Microsoft\Windows\CurrentVersion\Run	Autoruns, Velociraptor
Malicious attachment	Invoice_urgent.xls	Any.run sandbox, Hybrid Analysis
Affected username	DOMAIN\jsmith (SAM account)	AD logs, SIEM user pivot

IOC enrichment workflow: Copy IP → paste into AbuseIPDB → copy domain → check VirusTotal → copy hash → search in EDR (CrowdStrike) → tag all confirmed malicious IOCs with TLP:RED in ticket.

3. Scenario 1 — Phishing Attack

Severity	Business Impact	Likelihood
High	Credential theft · Business Email Compromise · Malware delivery	Very High — #1 attack vector globally

Detection Triggers

- SIEM Rule: Email gateway detects >3 failed SPF/DKIM/DMARC checks from same sender domain
- SIEM Rule: User clicks link flagged by URL reputation feed (VirusTotal score >50)
- SIEM Rule: Credential submission to external domain within 2 min of email receipt
- User report: 'I received a suspicious email from my CEO asking for gift cards'

Triage → Containment → Eradication

Triage (0–15 min)	Pull original email headers. Check: Return-Path vs From mismatch, Received hops, X-Originating-IP. Extract sender domain → check MX records, registration date (new domain = high risk). Search SIEM: how many users received this email? Did anyone click? Did anyone submit credentials? Assign severity: P1 if credentials submitted, P2 if link clicked, P3 if email received only.
Containment (15–45 min)	Block sender domain at email gateway (Proofpoint/O365 blocked senders). Pull all mailboxes that received the email → quarantine via admin center. If credential submission confirmed: immediately force password reset for affected user + disable all active sessions (Entra ID: Revoke sessions). If malware attachment opened: isolate endpoint from network (CrowdStrike Network Contain).
Eradication (45 min–2 hrs)	Purge all instances of phishing email from all mailboxes (O365: Content Search → Purge). Check affected user's sent items, inbox rules, and forwarding settings for BEC persistence. Reset credentials, enforce MFA re-enrollment. Search EDR for any dropped files or process executions triggered by the attachment. Block malicious URLs and IPs at perimeter firewall.
Recovery	Monitor affected account for 72 hrs post-reset. Validate no forwarding rules remain. Brief affected user — phishing awareness refresher. Restore any emails incorrectly quarantined.
Lessons Learned	Did DMARC enforcement fail? Why? Was the user trained? Update email gateway rule with new sender TLD pattern. Add IOCs (domain, IP, hash) to threat intel blocklist. Write post-incident report within 5 business days.

Email Header Analysis — Step by Step

- Open raw email headers (Gmail: three dots → Show original | Outlook: File → Properties → Internet Headers)
- Check **From:** vs **Return-Path:** — a mismatch is a red flag (spoofing indicator)
- Check **Received:** chain — trace the sending server IP from bottom to top
- Look up the originating IP in AbuseIPDB and Shodan
- Check **Authentication-Results:** — SPF=fail, DKIM=fail, DMARC=fail = confirmed spoofing
- Extract any URLs from body — defang them (replace . with [.]) before pasting into VirusTotal
- Document all findings in the incident ticket with timestamps

4. Scenario 2 — Ransomware Outbreak

Severity	Business Impact	Likelihood
Critical	Data encryption · Business disruption · Financial loss · Regulatory breach	High — typically follows phishing or unpatched RDP

Detection Triggers

- SIEM Rule: Mass file rename events — >500 files with new extension (.locked, .encrypted, .WNCRY) within 60 sec
- SIEM Rule: Shadow copy deletion command — vssadmin delete shadows /all /quiet
- SIEM Rule: Unusual SMB lateral movement — one host connecting to 10+ internal hosts in 5 min
- SIEM Rule: Ransom note file created — README_DECRYPT.txt, HOW_TO_RESTORE.html
- EDR Alert: Process injection into lsass.exe or credential dumping attempt (Mimikatz signature)

Triage → Containment → Eradication

Triage (0–10 min) ACT FAST

Confirm: is this live ransomware or a false positive? Check EDR process tree — look for PowerShell → certutil → wscript chain. Identify patient zero: which host triggered the first file rename alert? Determine blast radius: how many hosts show similar alerts? Check network shares for ransom notes. Declare P1 Major Incident immediately. Notify CISO and management. Do NOT reboot any affected systems.

Containment (10–30 min)

IMMEDIATE: Network isolate patient zero via EDR (CrowdStrike Network Contain — one click). Disable affected user's AD account. Block identified C2 IPs and domains at perimeter firewall. Segment affected network subnet at switch level if spread is detected. Preserve memory dump before isolation if forensically safe. Do NOT pay ransom without executive + legal approval.

Eradication (2–8 hrs)

Identify ransomware family using ransom note + file extension → check ID Ransomware (id-ransomware.malwarehunterteam.com). Check for free decryptors at No More Ransom (nomoreransom.org) before any other action. Wipe and rebuild affected endpoints from golden image — do not trust any restore from infected disk. Identify and close the initial access vector (unpatched RDP? phishing? stolen VPN creds?). Reset ALL privileged account credentials across the environment.

Recovery

Restore data from last known clean backup — validate backup integrity first. Bring systems online in isolated environment, monitor for 48 hrs before full production return. Harden: patch RDP, enforce NLA, disable SMBv1, enable Windows Defender Credential Guard.

Lessons Learned

Root cause analysis: how did ransomware get in? How did it spread so far? Were backups truly offline/immutable? Update DR plan with lessons. Conduct tabletop exercise within 30 days.

5. Scenario 3 — Insider Threat

Severity	Business Impact	Likelihood
High	Data exfiltration · IP theft · Sabotage · Reputational damage	Medium — often detected late due to trusted access

Detection Triggers

- SIEM Rule: Large data download — user downloads >500 MB from SharePoint/OneDrive outside business hours
- SIEM Rule: Mass email to personal address — >20 emails with attachments to a Gmail/Yahoo account
- SIEM Rule: USB mass storage device connected to corporate endpoint (DLP alert)
- SIEM Rule: Access to resources outside normal role — Finance analyst accessing HR database at 02:00
- HR trigger: Employee submitted resignation 48 hrs ago — flag for enhanced monitoring per policy

Triage → Containment → Eradication

Triage (0–30 min)	Pull full activity log for the user: last 30 days of file access, email, web proxy, VPN, badge entry. Establish baseline — is this behaviour anomalous vs their normal pattern? Cross-reference with HR: any performance issues, resignation, disciplinary action, access disputes? Do NOT alert the user or their manager at this stage — preserve evidence and element of surprise. Loop in Legal and HR immediately — insider threat investigations have legal implications.
Containment (Covert phase)	Apply enhanced monitoring: capture full packet logs for user's sessions, enable DLP alerting on all channels. Do not block access yet — covert monitoring builds evidence. Preserve all logs to tamper-evident storage (cannot be deleted by user or admin). If immediate data exfiltration in progress: block specific channel only (e.g. USB port via GPO), not full access.
Eradication (Post-investigation)	Once HR/Legal confirms action: immediately revoke all access (AD, VPN, cloud apps, physical badge). Audit all data accessed and exfiltrated — prepare evidence package for legal proceedings. Identify any backdoors or accounts created by the insider. Review access permissions for all peers in same team — principle of least privilege audit.
Recovery	Reassign critical system ownership. Update shared passwords the user knew. Review and tighten DLP policies. Enable UBA (User Behaviour Analytics) if not already active.
Lessons Learned	Was access provisioning following least privilege? Were offboarding procedures timely (access revoked within 1 hr of resignation)? Update insider threat policy with specific monitoring triggers.

6. MITRE ATT&CK Quick Reference

Scenario	TTP ID	TTP Name	Detection Method
Phishing	T1566.001	Spearphishing Attachment	Email gateway, sandbox detonation
Phishing	T1566.002	Spearphishing Link	URL filtering, proxy logs
Phishing	T1078	Valid Accounts (post-creds)	UEBA anomaly, MFA enforcement
Ransomware	T1486	Data Encrypted for Impact	File integrity monitoring, EDR
Ransomware	T1490	Inhibit System Recovery	VSS delete command detection
Ransomware	T1021.002	Lateral Move via SMB	SMB traffic anomaly, firewall logs
Ransomware	T1003.001	LSASS Memory Dump	EDR credential access alert
Insider Threat	T1567	Exfil over Web Service	DLP, proxy, CASB logs
Insider Threat	T1052.001	Exfil via USB	Device control policy, DLP
Insider Threat	T1078	Valid Account Abuse	UEBA, access time anomaly

7. Escalation Matrix & Communication Template

Priority	Response SLA	Escalation Path
P1 — Critical (Ransomware, active breach)	0–15 min	SOC Lead → CISO → Legal → Exec → PR (if data breach)
P2 — High (Phishing w/ cred compromise)	0–30 min	SOC Lead → IT Manager → Affected user's manager
P3 — Medium (Phishing email received, no click)	0–2 hrs	SOC Analyst → Ticket system → User notification
P4 — Low (Suspicious email, no interaction)	0–4 hrs	SOC Analyst → Log and monitor → User awareness email

Initial Incident Notification Template

Use this template for the first stakeholder communication within 15 minutes of P1/P2 declaration:

```
Subject: [P1 INCIDENT] Ransomware Activity Detected – [Date] [Time] IST
Summary: At [TIME], SOC detected [ALERT TYPE] on [SYSTEM/USER]. Containment actions initiated at [TIME]. Current blast radius: [X hosts / Y users affected]. Estimated business impact: [LOW / MEDIUM / HIGH]. Next update in 30 minutes. IR lead: [NAME]. Ticket: [ID].
```

This playbook is a living document. Review and update after every major incident and quarterly during tabletop exercises. Last reviewed: May 2026 · Owner: Nivedhitha K.S.